# Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently have this control in place?*

**Controls assessment checklist**

| Yes | No | Control |
|---|---|---|
| ☐ | ☑ | Least Privilege |
| ☐ | ☑ | Disaster recovery plans |
| ☑ | ☐ | Password policies |
| ☐ | ☑ | Separation of duties |
| ☑ | ☐ | Firewall |
| ☐ | ☑ | Intrusion detection system (IDS) |
| ☐ | ☑ | Backups |
| ☑ | ☐ | Antivirus software |
| ☑ | ☐ | Manual monitoring, maintenance, and intervention for legacy systems |
| ☐ | ☑ | Encryption |
| ☐ | ☑ | Password management system |
| ☑ | ☐ | Locks (offices, storefront, warehouse) |
| ☑ | ☐ | Closed-circuit television (CCTV) surveillance |
| ☑ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) |

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

**Compliance checklist**

Payment Card Industry Data Security Standard (PCI DSS)

| Yes | No | Best practice |
| --- | --- | --- |
| ☐ | ☑ | Only authorized users have access to customers' credit card information. |
| ☐ | ☑ | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. |
| ☐ | ☑ | Implement data encryption procedures to better secure credit card transaction touchpoints and data. |
| ☐ | ☑ | Adopt secure password management policies. |

General Data Protection Regulation (GDPR)

| Yes | No | Best practice |
| --- | --- | --- |
| ☐ | ☑ | E.U. customers' data is kept private/secured. |
| ☑ | ☐ | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. |
| ☐ | ☑ | Ensure data is properly classified and inventoried. |
| ☑ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |

System and Organizations Controls (SOC type 1, SOC type 2)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | User access policies are established. |
| ☐ | ☑ | Sensitive data (PII/SPII) is confidential/private. |
| ☑ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☑ | Data is available to individuals authorized to access it. |

---

**Recommendations (optional):** *In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.*

First, the lack of encryption and centralized password management, and the insecure password policy needs to be immediately addressed. The IT department can start by implementing encryption in the company's database and then updating the company's password policy and ensuring that it goes in line with current minimum password complexity requirements. Next is to establish a centralized password management system not only to enforce the password policy's minimum requirements but to also help reduce the affected productivity of both employees and vendors.

Second, the lack of disaster recovery plans is highly concerning. Botium Toys has no plan for how to get back to work after an attack, a power failure, or a natural disaster, and it also has no backups of its critical data. This puts both the business and people at risk. The IT department should write a disaster recovery plan and make regular backups of critical data and customer records. The backups should be stored in a safe and secure place, and the IT department should test them often to make sure they work.

Third, the company should improve its access controls. Every employee can access customer card data and personal information at the moment. The IT department should apply the principle of least privilege and separation of duties, so that each person can only see the data they need for their job and that no single person can control a whole process on their own. Then the implementation of IDS can further help the IT department by detecting early signs of possible intrusion events.

Lastly, Botium Toys should work toward full compliance with PCI DSS and GDPR. This step comes last because the earlier steps already meet most of what these rules ask for. Once those are in place, the company will only need to close the small gaps that remain and keep records to prove it.